Legal Feasibility Study Report

Livrable du projet T-LAW-901

Réalisé par Justin MBODJE, Yasser MEKHFI, Jérémy COQUELIN, Mohamed FOFANA, Mattéo COGAN, Romain CROCQ-MARCHAND, Tristan CHARDES

Établissement de formation : EPITECH RENNES

Promotion 2026

1- Présentation générale du projet

Corevia est une solution numérique de santé développée dans le cadre du projet ESP. L'application se positionne comme un outil d'accompagnement continu pour les individus atteints de maladies chroniques ou souhaitant suivre leurs indicateurs de santé au quotidien. Elle offre une interface sécurisée permettant la saisie et la consultation de mesures médicales, la planification de rappels thérapeutiques, l'accès à un assistant d'analyse de symptômes fonctionnant via un modèle d'intelligence artificielle, ainsi qu'un ensemble de conseils personnalisés fondés sur l'état de santé de l'utilisateur. L'écosystème comprend une application web, un microservice d'IA, une application mobile et une infrastructure cloud reposant principalement sur AWS et divers outils techniques d'orchestration.

Le projet implique un traitement structuré et régulier d'informations relevant de la sphère intime, notamment des données de santé, ce qui lui confère un statut juridique particulier au regard du RGPD. Par ailleurs, l'intégration d'un modèle d'IA externe via l'API Mistral impose également le respect des obligations issues du futur IA Act, qui encadre les systèmes présentant des risques accrus dans les domaines sensibles tels que la santé. Enfin, l'architecture distribuée, les multiples prestataires techniques, et la dimension logicielle propriétaire et open-source exigent une analyse transversale de conformité, de responsabilité et de protection des droits.

Cette étude vise donc à déterminer si le projet Corevia est juridiquement faisable, à identifier les risques associés à son déploiement et à proposer des mesures correctives adaptées afin de garantir la conformité de la solution.

2 - Analyse des enjeux juridiques majeurs du projet

La première catégorie d'enjeux concerne la protection des données personnelles, et plus particulièrement des données dites « sensibles ». Corevia traite des mesures médicales telles que la tension, la glycémie, l'IMC ou d'autres indicateurs relevant de la santé de l'utilisateur. Ces informations entrent dans le champ de l'article 9 du RGPD, imposant une base légale adéquate, une justification stricte et la mise en œuvre de mesures de sécurité

renforcées. Dans le cadre de ce projet, le choix est fait de fonder le traitement sur le consentement explicite de l'utilisateur, obtenu de manière claire et indépendante pour chaque fonctionnalité impliquant la manipulation de données de santé. Ce choix permet de satisfaire les exigences réglementaires, mais implique également que le service doit cesser le traitement si le consentement est retiré, et qu'un droit de suppression complet doit être garanti.

Au-delà du fondement légal, la protection des données requiert également la mise en place de dispositifs techniques et organisationnels robustes. Le projet prévoit une architecture dans laquelle les données sensibles sont centralisées et stockées sur des instances AWS certifiées HDS, ce qui répond aux obligations françaises relatives à l'hébergement de données de santé. L'utilisation du chiffrement AES-256 pour les données au repos et des protocoles TLS pour les échanges contribue à assurer la confidentialité, tandis que la journalisation systématique des accès permet de répondre aux principes d'intégrité et de traçabilité. Des processus d'anonymisation ou de pseudonymisation sont également prévus lorsque les données ne nécessitent plus d'être liées directement à l'utilisateur. Ces mesures témoignent d'une volonté de respecter pleinement les exigences du RGPD en matière de minimisation, de limitation de conservation et de protection.

L'intégration d'un système d'intelligence artificielle constitue une autre dimension juridique essentielle. Le modèle Mistral, utilisé via une API externe, reçoit certains éléments textuels fournis par l'utilisateur, éventuellement liés à son état de santé. Bien que l'IA ne délivre pas de diagnostic médical, son rôle d'assistance dans l'analyse des symptômes place cette fonctionnalité dans un périmètre réglementaire prochainement renforcé par le futur IA Act. Ce règlement prévoit une catégorisation des systèmes selon leur niveau de risque, et les systèmes utilisés dans le domaine de la santé peuvent être qualifiés de « systèmes à haut risque ». Cela impose des obligations supplémentaires telles que la transparence sur le fonctionnement de l'algorithme, la documentation des limites du système, la capacité à justifier les recommandations produites, la mise en place d'un contrôle humain, ainsi que des exigences renforcées en termes de qualité des données et de gestion des biais. Corevia devra par conséquent encadrer strictement l'usage de l'IA en proscrivant toute production automatique de diagnostic ou d'interprétation médicale, en informant clairement les

utilisateurs du caractère généré des réponses, et en conservant une traçabilité des interactions avec le système d'IA.

L'usage de sous-traitants techniques constitue également un point central. L'application repose sur la combinaison de divers services tels que GitHub, Netlify, Pinecone ainsi que plusieurs services AWS. Chacun de ces prestataires peut être susceptible de traiter ou d'accéder à des données personnelles, ce qui en fait des sous-traitants au sens du RGPD. Le recours à plusieurs infrastructures implique de garantir que les données sensibles ne quittent jamais un environnement certifié HDS, et que les autres prestataires ne reçoivent que des données pseudonymisées ou non sensibles. Il est impératif d'encadrer contractuellement les relations avec ces sous-traitants via des accords de traitement (DPA), d'évaluer leur conformité, et de contrôler la localisation des données afin d'éviter les transferts non encadrés vers des pays tiers.

Enfin, la propriété intellectuelle ainsi que la gestion des droits sur le code source constituent un autre enjeu. Corevia étant développé au sein d'une structure pédagogique mais avec une intention d'exploitation potentielle, il est essentiel de s'assurer que l'ensemble du code appartient bien à Corevia SAS. Les contributions doivent faire l'objet de cessions explicites et conformes au droit français. Le recours à de nombreuses bibliothèques open-source impose également une vigilance particulière quant aux obligations attachées aux licences, notamment pour éviter l'utilisation de composants soumis à des licences copyleft susceptibles d'imposer une ouverture involontaire du code source de l'application.

3 - Évaluation des risques et mesures d'atténuation

L'analyse effectuée met en évidence plusieurs risques juridiques. Le premier est le risque de non-conformité au RGPD, en particulier en raison de la nature très sensible des données traitées. Une telle non-conformité pourrait entraîner des sanctions élevées, impliquant à la fois des risques financiers et réputationnels. Toutefois, la mise en œuvre d'un registre des traitements, la définition claire des finalités, l'obtention systématique du consentement

explicite, et le recours à des solutions d'hébergement HDS permettent de réduire considérablement ce risque.

Le deuxième risque réside dans l'utilisation de l'intelligence artificielle. Une IA entraînée à partir de données externes et utilisée dans un contexte de santé peut conduire à des interprétations incorrectes ou à des réponses mal comprises par les utilisateurs. Pour atténuer ce risque, Corevia prévoit une limitation stricte du rôle de l'IA, qui se limite à fournir des indications générales sans valeur médicale. Les messages sont formulés pour encourager la consultation d'un professionnel et pour rappeler que l'analyse produite ne remplace pas une expertise médicale. La supervision humaine et la documentation des interactions viennent renforcer cette maîtrise du risque.

Le recours à des prestataires externes constitue un troisième risque important, notamment lorsque des données personnelles circulent entre plusieurs infrastructures. La stratégie retenue consiste à limiter au maximum les déplacements de données, à compartimenter l'architecture entre environnements sensibles et non sensibles, et à vérifier que l'ensemble des services utilisés répond aux standards de sécurité requis. Le recours systématique au chiffrement ainsi qu'à des contrôles d'accès granulaires permet de réduire la surface d'attaque.

Enfin, les risques liés à la propriété intellectuelle ne doivent pas être ignorés. Sans cession claire des droits des contributeurs, Corevia SAS s'exposerait à des litiges potentiels. La sécurisation contractuelle, associée à un audit régulier des licences open-source utilisées, permet de garantir que l'ensemble du patrimoine logiciel du projet est juridiquement maîtrisé.

4 - Conclusion sur la faisabilité juridique du projet

L'étude menée démontre que le projet Corevia est juridiquement réalisable et qu'aucun obstacle légal rédhibitoire ne compromet son développement. Le cadre réglementaire, bien que strict, est compatible avec les choix techniques et organisationnels opérés par le projet. Le traitement de données de santé impose des obligations importantes, mais les mesures

envisagées, notamment l'hébergement HDS, le chiffrement systématique, la gestion rigoureuse des accès et la conformité RGPD, permettent de respecter ces exigences. De même, l'usage de l'IA, bien que sensible, peut être maîtrisé grâce à une conception prudente, une transparence renforcée et une documentation adéquate répondant aux critères du futur IA Act.

Pour garantir une conformité durable, Corevia devra maintenir une vigilance constante, mettre à jour régulièrement sa documentation, suivre les évolutions réglementaires et procéder à des audits de sécurité. Toutefois, à ce stade, l'ensemble des risques identifiés apparaît maîtrisable et la stratégie juridique proposée permet de conclure de manière positive quant à la faisabilité du projet.

ANNEXE – Liens officiels

IA Act (Parlement Européen)

https://artificialintelligenceact.eu/ai-act-explorer/

Texte complet du Règlement (UE) 2016/679 (RGPD) — EUR-Lex https://eur-lex.europa.eu/eli/reg/2016/679/oj?locale=fr EUR-Lex+1

Page CNIL — RGPD & obligations pour les traitements de données

https://www.cnil.fr/fr/reglement-europeen-protection-donnees CNIL

CNIL — Page “Notifier une violation de données personnelles” (formulaire et obligations 72h)

https://www.cnil.fr/fr/services-en-ligne/notifier-une-violation-de-donnees-personnelles CNIL+1

CNIL — Guide “Violations de données personnelles : les règles à suivre”

https://www.cnil.fr/fr/violations-de-donnees-personnelles-les-regles-suivre CNIL+1

Site officiel service-public.fr — Démarche pour signaler une violation de traitement de données personnelles

https://www.service-public.fr/particuliers/vosdroits/R69084 Service Public+1

Informations sur les droits des personnes sous RGPD (accès, suppression, portabilité, consentement) — CNIL

https://www.cnil.fr/fr/passer-laction/les-droits-des-personnes-sur-leurs-donnees CNIL+1